

HOW TO BUILD A PRIVACY AND DATA PROTECTION PROGRAM

A concise, practical implementation manual

Alberto (Al) Leiva

Version 1.0 - July 2026

Purpose

Use this manual for lawful, authorized, defensive work. Adapt controls to organizational risk, legal obligations, accessibility needs, and available resources.

Governance and scope

- Assign accountable privacy leadership and define roles across legal, security, data, product, HR, procurement, and operations.
- Identify applicable laws, contracts, jurisdictions, and regulator expectations.
- Use qualified legal counsel for jurisdiction-specific interpretation.

Data inventory and mapping

- Record data categories, subjects, purpose, source, systems, locations, recipients, transfers, retention, and owner.
- Include structured and unstructured data, logs, backups, analytics, AI prompts, models, and vendor copies.
- Keep maps current through change management.

Purpose, minimization, and transparency

- Collect only data needed for a defined purpose.
- Provide clear notices and avoid misleading consent.
- Prevent incompatible secondary use without review and authority.

Data-subject rights

- Create verified, accessible workflows for access, correction, deletion, objection, portability, and appeal where applicable.
- Search all relevant systems and vendors.
- Track deadlines, decisions, exemptions, and evidence.

Privacy engineering and security

- Apply privacy by design during requirements, architecture, development, testing, and retirement.
- Use access control, encryption, tokenization, masking, isolation, logging, and secure deletion.
- Assess re-identification and inference risk.

Vendors, transfers, and AI

- Review processors, subprocessors, contracts, transfer mechanisms, incidents, deletion, and audit evidence.
- Assess AI training use, prompt retention, profiling, automated decisions, bias, transparency, and human oversight.
- Prohibit sensitive data use in unapproved tools.

Incidents, metrics, and roadmap

- Integrate privacy breach assessment with incident response.
- Measure inventory coverage, overdue requests, retention violations, high-risk assessments, vendor gaps, and incident trends.
- Days 1-30: governance and high-risk data map. Days 31-60: rights, retention, vendor clauses, and assessments. Days 61-90: automation, testing, metrics, and management review.

Implementation checklist

- ☐ Owner assigned
- ☐ Scope approved
- ☐ Inventory complete
- ☐ Risks prioritized
- ☐ Policies documented
- ☐ Controls implemented
- ☐ Evidence retained
- ☐ Exceptions expire
- ☐ Testing completed
- ☐ Management review recorded

Official references

- NIST Privacy Framework 1.1: <https://www.nist.gov/privacy-framework/privacy-framework>
- Using Privacy Framework 1.1: <https://www.nist.gov/privacy-framework/using-privacy-framework-11>
- NIST CSF 2.0: <https://www.nist.gov/cyberframework>

License

Copyright © 2026 Alberto (Al) Leiva. Licensed under CC BY-NC-SA 4.0.